Detección de problemas de seguridad en aplicaciones para dispositivos móviles.

Caso práctico

Julián ha terminado de trabajar en el proyecto del aplicativo web y ahora se ha embarcado en un nuevo proyecto para crear una app corporativa para los móviles de los empleados de una empresa. Está revisando aún las funcionalidades que requiere el cliente y pensando cómo y de qué manera podría abordarlas.



@tdcat para Pexels. *black-and-gray-digital-device* (Uso gratuito Licencia Pexels)

Uno de las preocupaciones que está en la cabeza de Julián es el gran número de requisitos que debe de cumplir su app para subirla a las principales tiendas de aplicaciones (Play Store, App Store, ...). Sabe que debe de acometer distintos procesos (reflejar permisos, firmar la app, etc) y que su aplicación tendrá que ser segura o podrían retirarla fácilmente de la tienda.

Por otra parte, la aplicación a desarrollar tiene que ser compatible con la tecnología de CASB que tiene el cliente, permitiendo el flujo de comunicación normal de la app y la comunicación con servicios externos.

Hoy en día debido a la cantidad de datos que posee sobre su dueño los teléfonos móviles se han convertido en el objetivo de los cibercriminales. Ya sea de forma directa o mediante apps maliciosas los atacantes buscan entrar a los datos contenidos en el dispositivo.

Durante los últimos meses varios programas (software o apps) maliciosos que controlan y espían el dispositivo móvil del usuario se han hecho famosos. Lo cierto es que, aunque pareciera no ser suficiente, los dispositivos cuentan con diversas protecciones ante este tipo de amenazas. Para ello el sistema operativo de los teléfonos móviles usan mecanismos para proteger la seguridad de los datos. Uno de los principales mecanismos de protección frente a apps maliciosas es el ***sandboxing***, es decir, las aplicaciones corren en un entorno controlado y aislado para limitar el acceso y los permisos al sistema y a los datos.

GOBIERNO DE ESPAÑA
MINISTERIO DE EDUCACIÓN, FORMACIÓN PROFESIONAL Y DEPORTES

Ministerio de Educación, Formación Profesional y Deporte. (Dominio público)

Materiales formativos de FP Online propiedad del Ministerio de Educación, Formación Profesional y Deportes.

Aviso Legal

1.- Modelos de permisos en plataformas móviles. Llamadas al sistema protegidas.

Caso práctico



StockSnap. *Portatil, programación código* (Licencia de Pixabay)

Julián sabe que para entender las vulnerabilidades de las aplicaciones móviles debe centrarse en los aspectos más importantes de seguridad de las mismas. Uno de estos aspectos son los **modelos de permisos en las distintas plataformas móviles.**

Cada plataforma define un esquema de permisos, de manera que toda aplicación que acceda a determinados recursos está obligada a declarar su intención de usarlos. En caso de que una aplicación intente acceder a un recurso del que no ha solicitado permiso, se generará una excepción de permiso y la aplicación será interrumpida inmediatamente.



@freestocks para Pexels. *mano-telefono-inteligente-tecnologia-telefono-movil* (Uso gratuito Licencia Pexels)

Tanto en iOS como en Android (principales sistemas operativos móviles) todas las aplicaciones se ejecutan en su propio *sandbox* o entorno aislado. En Android cada aplicación está funcionando con un usuario especifico que se crea para esa aplicación mientras que en iOS todas las apps se ejecutan con el mismo usuario ("mobile") y cada aplicación tiene un directorio de inicio único para sus archivos, que se asigna aleatoriamente cuando se instala la aplicación.

Cuando una aplicación necesita acceder a partes de un sistema o a datos del usuario este tipo de acceso se considera protegido mediante permisos. Según cada plataforma funciona de manera distinta.

Cuando se instala una aplicación en Android que necesita acceder a alguna funcionalidad (fotos, cámara, contactos, etc) solicita al usuario permiso durante la instalación y el usuario verificará si es lícito o no. Existen dos niveles de acceso, accesos estándar o los más especiales o peligrosos. Una aplicación no podrá acceder a este tipo de funcionalidades o datos sin el consentimiento explícito del usuario. Las aplicaciones deben declarar antes de publicarse en la tienda oficial a que recursos necesitan tener acceso.

En iOS los permisos funcionan de manera algo distinta: las apps pueden acceder sólo a determinadas funciones que el sistema habilita, el resto no está permitido. Cuando una app necesita acceder a información del usuario usa un concepto de *entitlement* o permiso que está firmado digitalmente. Cuando una aplicación desea acceder a la cámara, fotos, ubicación o demás permisos, requiere que sea aprobado de forma explícita por el usuario de forma muy parecida a como sucede en Android.

Otro problema de seguridad adicional viene de la instalación de apps de terceros, fuera de la tienda oficial o bajadas de sitios web de dudosa reputación, si bien al final vuelven a necesitar que el usuario consienta el acceso (caso de Android) o no podrá acceder a menos de que tenga firmado ese acceso o el sistema lo permita (caso de iOS).



Para saber más

Existen numerosos tipos de permiso en el sistema Android, si quieres conocer en detalle cuales son y de qué manera se relacionan con la actividad del usuario puedes consultar más información en el siguiente enlace de la página para desarrolladores de Android.

2.- Firma y verificación de aplicaciones.

Caso práctico

Otro aspecto de la seguridad de las aplicaciones web, en la que debe centrarse **Julián,** es la **firma y verificación de las aplicaciones**. El proceso de firma y verificación de aplicaciones en aplicaciones móviles ayuda a garantizar que solo las aplicaciones auténticas y confiables, firmadas por desarrolladores verificados, puedan instalarse en los dispositivos.



@danny144 para Unsplash. *móvil iphone 5c en escritorio*
(Uso gratuito Licencia Unsplash)

Como comentábamos uno de los riesgos es el origen de las aplicaciones, es decir las tiendas o webs de aplicaciones de las plataformas móviles. Durante muchos años han sido un foco de *Malware* las tiendas no oficiales, los usuarios que descargan apps en webs de dudosa reputación e incluso aplicaciones poco recomendables disponibles en la tienda oficial.



freepik. *close-up-hand-holding-phone* (Uso gratuito Licencia Freepik)

Para solucionar estos problemas, actualmente todas las aplicaciones para móviles deben de pasar estrictos controles en la tienda oficial de apps. Uno de estos controles son las **firmas digitales**; las apps deben de estar firmadas por el desarrollador y si no lo están serán rechazadas por la tienda y además el instalador del dispositivo no permitirá instalarla.

Dentro de los controles establecidos por las tiendas oficiales para alojar una app, podríamos destacar:

- Una revisión exhaustiva de la la interacción que hacen con los datos de usuario.
- Los permisos que solicitan o requieren.
- Actualizaciones periódicas.
- Seguir y cumplir una serie de normas y políticas establecidas por la tienda oficial, etc.

Debes conocer

Para saber algo más sobre los procesos de firma y verificación, puedes consultar en los siguientes enlaces las políticas de firma para desarrolladores de dos de las tiendas oficiales más populares: **App Store** (Apple) y **Play Store** (Google):

- Proceso de firma de código de apps en iOS y iPadOS
- Proceso de firma de app en Google

Autoevaluación

Identifica si las siguientes frases son verdaderas o falsas

Una aplicación puede acceder a los datos del dispositivo móvil sin autorización previa

○ Verdadero ○ Falso

Falso

Todo acceso a datos del tanto del usuario como funcionalidades debe hacerse a través de permisos.

Cualquiera puede subir una aplicación a una de las tiendas oficiales sin apenas control.

○ Verdadero ○ Falso

Falso

Las aplicaciones que se suben a la tienda oficial pasan distintos controles de seguridad para garantizar su seguridad y la de los usuarios.

Los dispositivos móviles se han convertido en un objetivo de los cibercriminales.

○ Verdadero ○ Falso

Verdadero

Contienen gran cantidad de información y de mucho valor.

Durante los últimos meses han surgido software malicioso para móviles que es capaz de monitorizar y espiar la actividad y datos de los usuarios.

○ Verdadero ○ Falso

Verdadero

Un ejemplo sería el software Pegasus.

3.- Almacenamiento seguro de datos.

Caso práctico



GDJ en Openclipart. *eu-gdpr* (CC0)

Aunque las aplicaciones hayan sido verificadas y el usuario haya consentido su uso y los permisos necesarios para que la app funcione, **Julián** sabe que un punto clave es el **almacenamiento de datos dentro del dispositivo móvil**. Este proceso es de vital importancia ya que habrá mucha información de carácter personal por lo que habrá que prestar atención a todo lo referente al nuevo **Reglamento General de Protección de Datos** (GDPR), que es el nuevo reglamento a nivel europeo para el tratamiento de datos personales.

Julián ha accedido a la versión en castellano del GDPR en este enlace _y cree que, prácticamente todo el mundo, debería tener conocimiento de los derechos y deberes que establece en cuanto a la privacidad y la protección de datos.



bloodsong. *keyring-icon* (CC0)



Dustwin. *Digital Encryption Icon* (CC0)

La mayoría de sistemas operativos móviles consiguen dotar de seguridad a este proceso mediante el cifrado de los datos almacenados. Uno de los métodos más comunes consiste en cifrar todo el sistema de ficheros (con sistemas de cifrado tanto simétrico como asimétricos) para que, si un usuario externo consigue acceso al dispositivo, no pueda leer su contenido. Cuando el usuario legítimo introduce su clave o accede mediante reconocimiento biométrico, esta información se usa como clave para descifrar el sistema de ficheros y que el usuario pueda interactuar con los datos sin problemas.

Keystore es la herramienta que proporciona Android para generar y almacenar de forma segura las claves usadas en los algoritmos de cifrado de la información, ya sea para la fase de cifrado como para la fase de descifrado.

Para iOS, existe la posibilidad de usar **Keychain**. En este caso, a diferencia de la estrategia provista en Android, podemos usar directamente Keychain para almacenar la información sensible del usuario que

necesitemos, ya que la información que se almacena en Keychain será encriptada por el propio proceso que proporciona la API de Keychain. Sin embargo, también podemos usar Keychain de igual manera que se usa Keystore en Android, es decir, podemos usar Keychain para almacenar las claves que se usarán el proceso para cifrar y descifrar la información que almacenemos

Es de vital criticidad definir durante la fase de diseño de la aplicación una robusta y correcta estrategia para el almacenado de los datos sensibles del usuario, si queremos que nuestra aplicación cumpla con los requisitos de seguridad exigidos en nuestros días.



Debes conocer

El objetivo principal de securizar los datos del dispositivo móvil es prevenir la fuga de información del dispositivo.

4.- Validación de compras integradas en la aplicación.

Caso práctico

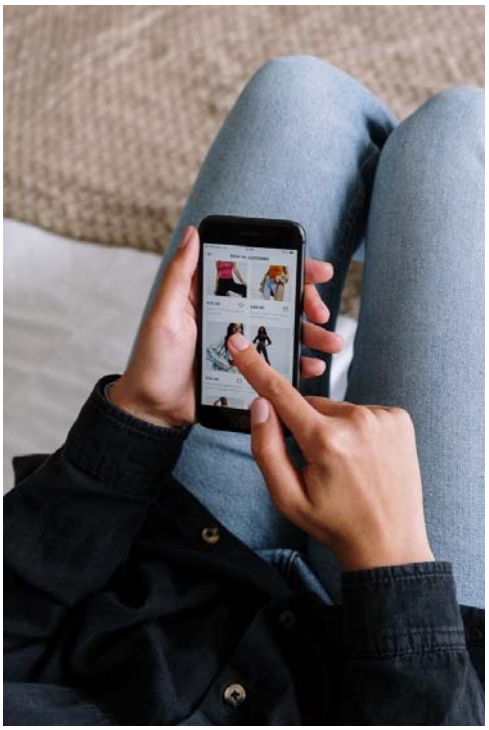


freepik. *close-up-hand-holding-phone* (Uso gratuito Licencia Freepik)

Uno de los aspectos en los que las plataformas de móviles ponen más énfasis es en prevenir el pago no autorizado de dinero a través de aplicaciones y sin el conocimiento del usuario del dispositivo. Teniendo en cuenta que ahora mismo no solamente es posible pagar a través del teléfono móvil sino que incluso podemos pagar desde los relojes inteligentes (*smartwatches)* **Julián** entiende que todo tiene que estar controlado y el usuario ser consciente.

La validación de compras integradas se vuelve esencial para prevenir fraudes, garantizar la autenticidad de las transacciones y proteger la información financiera de los usuarios. Los desafíos incluyen la falsificación de compras, el robo de identidad y la manipulación de datos de transacciones.

El proceso de compras a través de las aplicaciones sigue determinados mecanismos de protección, desde canales seguros de comunicaciones para prevenir ataques de Man-In-The-Middle cómo procesos de autenticación y validación expresa por parte del usuario.



@cottonbro en Pexels. *person-holding-black-android-smartphone* (Uso gratuito Licencia Pexels)

Veamos algunos de estos mecanismos:

1. **Criptografía y Firma Digital**:

   Implementar algoritmos de criptografía robustos y firmas digitales ayuda a asegurar la integridad de los datos de compra. Esto impide la manipulación de la información durante la transmisión, garantizando que solo las transacciones legítimas sean aceptadas.

2. **Autenticación Multifactor (AMF):**

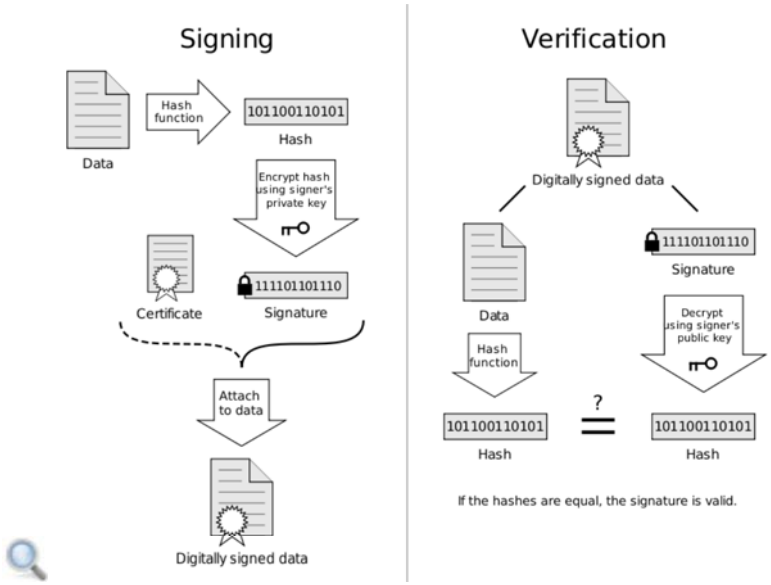
   La AMF añade una capa adicional de seguridad, exigiendo la verificación de la identidad del usuario mediante múltiples métodos, como contraseñas, códigos de un solo uso o biometría. Esto dificulta la usurpación de cuentas y fortalece la autenticación.

3. **Monitoreo de Patrones Anómalos**:

   La implementación de sistemas de monitoreo en tiempo real permite la detección temprana de patrones de actividad inusuales o transacciones sospechosas. Esto posibilita respuestas rápidas ante posibles amenazas y minimiza el impacto de posibles incidentes de seguridad.

Además, hay que fomentar la conciencia entre los usuarios sobre las mejores prácticas de seguridad,

como la importancia de proteger las credenciales de la cuenta y la necesidad de mantener sus dispositivos actualizados, contribuye significativamente a la prevención de ataques.



elis. *digital-signature-diagram* (CC0)

Debes conocer

Seguro que encuentras interesante este enlace de métodos de pago y su seguridad del blog de INCIBE

5.- Fuga de información en los ejecutables.

Caso práctico



StockSnap. *Portatil, programación código* (Licencia de Pixabay)

Julián sabe que los ejecutables de las aplicaciones móviles pueden ser analizados y manipulados. Este riesgo puede ser explotado por **ciberdelicuentes** con el objetivo de obtener información sensible, eludir medidas de seguridad, introducir malware o incluso realizar ataques de falsificación de identidad.

La **ingeniería inversa** de una aplicación móvil es el proceso de analizar la aplicación compilada para extraer información sobre su código fuente. Este proceso implica analizar el código binario (análisis estático del código) o la ejecución (análisis dinámico) de una aplicación con el objetivo de comprender su estructura interna y lógica de funcionamiento. Si bien este enfoque puede ser legítimo, como parte del análisis de seguridad por parte de los desarrolladores, también abre la puerta a posibles actividades maliciosas.

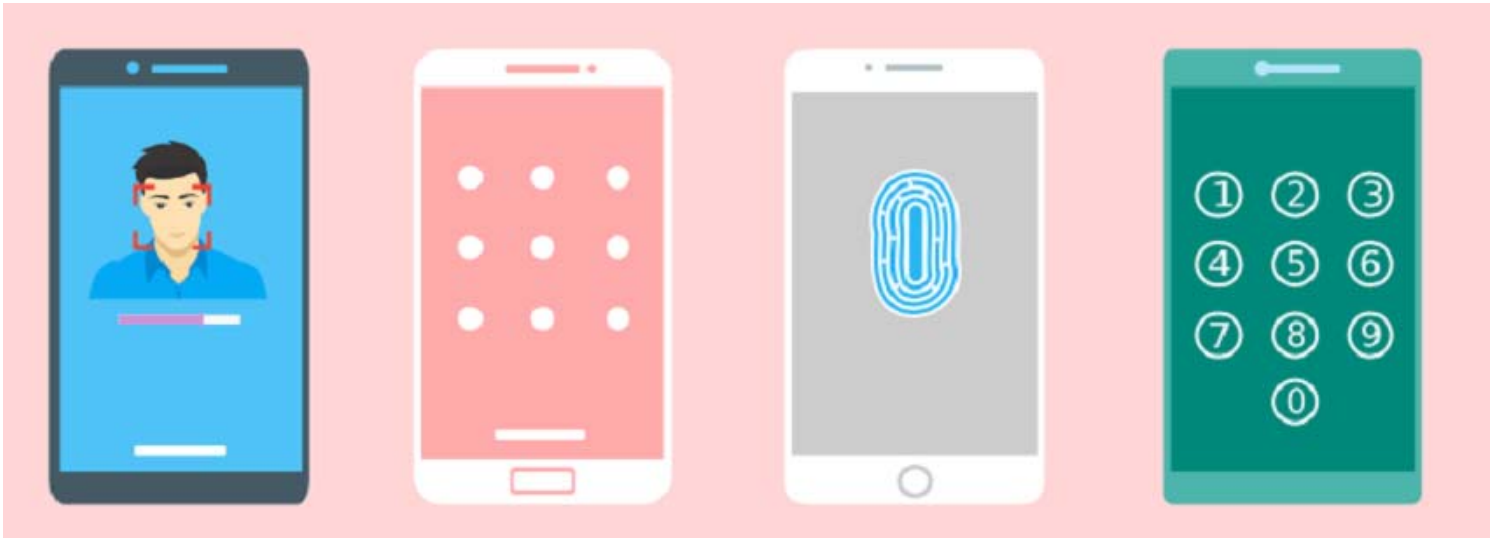


PBCrichton. *malware-hazard-symbol* (CC0)

Los ciberdelincuentes aprovechan la ingeniería inversa para descubrir información sensible de la aplicación, vulnerabilidades de seguridad y algoritmos críticos. Esta práctica, a menudo facilitada por herramientas de decompilación, permite la extracción no autorizada de información sensible, incluyendo claves de autenticación y datos críticos del usuario.

Además, existe la posibilidad del **Tampering**, o manipulación no autorizada de aplicaciones móviles, lo que implica alterar el código binario o su entorno para afectar a su comportamiento. Este riesgo puede ser explotado por ciberdelicuentes con el objetivo de eludir medidas de seguridad, introducir malware o incluso realizar ataques de falsificación de identidad.

Para mitigar estos riesgos, los desarrolladores y profesionales de ciberseguridad adoptan medidas defensivas, como la ofuscación de código, el cifrado robusto y la implementación de técnicas de detección de manipulación. Estas estrategias buscan no solo proteger la propiedad intelectual y la información confidencial, sino también preservar la integridad y la autenticidad de las aplicaciones móviles.



Vexagrafi. *phone-security-vector-pack* (CC0)

Para saber más

OWASP tiene un proyecto para las pruebas de seguridad de aplicaciones móviles (MASTG), mira este enlace si quieres saber mas sobre Ingeniería Inversa y Tampering y este otro enlace para ver algunas técnicas disponibles

6.- Soluciones CASB.

Caso práctico



StockSnap. *Portatil, programación código* (Licencia de Pixabay)

Julián sabe que muchas veces el dato no solamente está en el dispositivo sino también almacenado en servicios o aplicaciones que utilizan los entornos de nube o cloud . Los problemas que surgen en estos casos son varios, desde el poco control a no tener reglas de detección y bloqueo.

Además, y unido a situaciones como el teletrabajo, muchos usuarios hacen uso de sus dispositivos móviles personales para acceder a servicios en nube corporativos o de terceros perdiéndose la trazabilidad y control de la información. Estos servicios en nube incluyen desde correo hasta imágenes o ficheros.

Es aquí donde entra la tecnología de **CASB**.

Este tipo de tecnología viene a dar solución a estos problemas, aportando visibilidad sobre la información, monitorización y trazabilidad. Con esto podremos saber qué flujo sigue un determinado documento o qué tipo de información esta saliendo o entrando en un dispositivo móvil.



@scottwebb para Pexels. *two-gray-bullet-security-cameras* (Uso gratuito Licencia Pexels)

Hoy en día la tecnología de CASB se está extendiendo rápidamente por las empresas, ya que se han dado cuenta que no solamente es importante *securizar* tu entorno, servidores y demás, sino también los entornos de nube pero, sobre todo, los dispositivos móviles.

A nivel técnico funciona como un agente que se instala en el dispositivo y que recibe de forma centralizada la lista de políticas y reglas establecidas. De manera que, por un lado, se puede detectar que esta haciendo el dispositivo y, además, limitar el acceso a los servicios de nube o prevenir que se suba o baje determinada información de los mismos. Algunas soluciones de CASB avanzada disponen de capacidad **UEBA** que permite analizar patrones de comportamiento de los usuarios.

Finalmente la mayoría de soluciones consiguen cifrar los datos antes de enviarlos a la nube, lo que supone un control más y una capa de seguridad adicional para prevenir la fuga de información.

Para saber más

Si deseas conocer más sobre las soluciones de CASB, tanto a nivel de capacidades tecnológicas como de modelo operativo y algunos de los principales fabricantes de referencia de este tipo de tecnología puedes hacerlo en este enlace

Autoevaluación

Las soluciones de CASB aportan una capa mas de detección de fuga de información

○ Verdadero ○ Falso

Verdadero

Este tipo de tecnología aporta más capacidad de detección ante varios tipos de situaciones de riesgo.

Los sistemas operativos móviles y las apps no suelen implementar controles para las compras integradas.

○ Verdadero ○ Falso

Falso

Tanto los sistemas operativos como las propias aplicaciones garantizan que el proceso de compras sea seguro mediante varios mecanismos, desde el cifrado de comunicaciones como el consentimiento del usuario.

Los empleados de una compañía suelen usar para acceder a los datos tanto terminales corporativos como los suyos propios personales.

○ Verdadero ○ Falso

Falso

Los usuarios usan tanto terminales corporativos como sus propios dispositivos personales, mezclándose el ámbito privado y el profesional.

Los sistemas de CASB es la solución definitiva para la fuga de información en entornos de nube.

○ Verdadero ○ Falso

Falso

No se puede hablar nunca en seguridad de soluciones definitivas, ya que cada vez

los ataques son más avanzados, hay mas vulnerabilidades y los atacantes encuentran maneras de saltarse los controles establecidos.